

S I T E S U M M A R Y



F4 - LAB-WS01 Risk Assessment

6/16/2026

ISEP — Instituto Superior de Engenharia do Porto

Carlos

SELF ASSESSMENT

Disclaimer

The analysis, data, and reports in CSET® are provided “as is” for informational purposes only. The Cybersecurity & Infrastructure Security Agency (CISA) does not provide any warranties of any kind regarding any information contained within. In no event shall the United States Government or its contractors or subcontractors be liable for any damages, including but not limited to, direct, indirect, special, or consequential damages and including damages based on any negligence of the United States Government or its contractors or subcontractors, arising out of, resulting from, or in any way connected with this report, whether based on warranty, contract, tort, or otherwise, whether injury was sustained from, or arose out of the results of, or reliance upon the report.

CISA does not endorse any commercial product or service, including the subject of the assessment or evaluation in this report. Any reference to specific commercial products, processes, or services by trademark, manufacturer, or otherwise, does not constitute or imply its endorsement, recommendation, or favoring by CISA.

The display of the CISA official seal or other CISA visual identities on this report shall not be interpreted to provide the recipient organization authorization to use the official seal, insignia or other visual identities of CISA. The CISA seal, insignia, or other visual identities shall not be used in any manner to imply endorsement of any commercial product or activity by CISA or the United States Government. Use of the CISA seal without proper authorization violates federal law (e.g., 18 U.S.C. §§ 506, 701, 1017), and is against CISA policies governing usage of the seal.

The report is prepared and intended for internal use by the organization that made the request. The contents of this report may be subject to government or private intellectual property rights. To request distribution of this report outside the organization for which it was prepared, contact the CSET Program Office. The contents of this report may be reproduced or incorporated into other reports, but may not be modified without the prior express written permission of the CSET Program Office.

Advisory

The Cyber Security Evaluation Tool (CSET®) is only one component of the overall cybersecurity picture and should be complemented with a robust cyber security program within the organization. A self-assessment with CSET® cannot reveal all types of security weaknesses, and should not be the sole means of determining an organization's security posture.

The tool will not provide a detailed architectural analysis of the network or a detailed network hardware/software configuration review. It is not a risk analysis tool so it will not generate a complex risk assessment. CSET® is not intended as a substitute for in-depth analysis of control system vulnerabilities as performed by trained professionals. Periodic onsite reviews and inspections must still be conducted using a holistic approach including facility walk-downs, interviews, and observation and examination of facility practices. Consideration should also be given to additional steps including scanning, penetration testing, and exercises on surrogate, training, or non-production systems, or systems where failures, unexpected faults, or other unexpected results will not compromise production or safety.

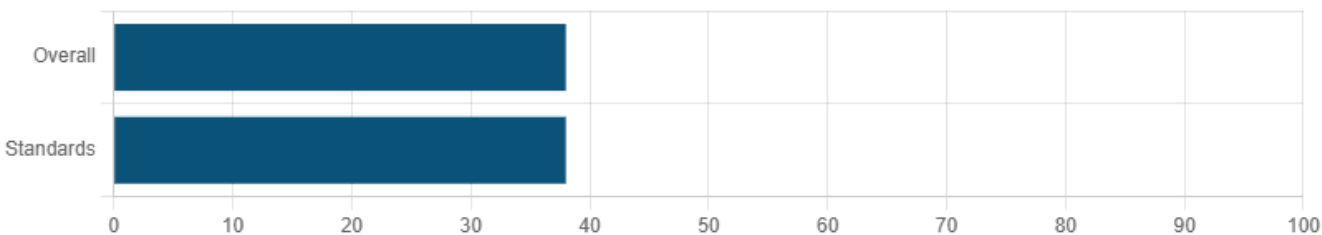
CSET® assessments cannot be completed effectively by any one individual. A cross-functional team consisting of representatives from operational, maintenance, information technology, business, and security areas is essential. The representatives must be subject matter experts with significant expertise in their respective areas. No one individual has the span of responsibility or knowledge to effectively answer all the questions.

Data and reports generated by the tool should be managed securely and marked, stored, and distributed in a manner appropriate to their sensitivity.

Site Information

Assessment Name	F4 - LAB-WS01 Risk Assessment
Assessment Date	6/16/2026
Facility Name	ISEP — Instituto Superior de Engenharia do Porto
City or Site Name	Porto
State, Province, or Region	Porto
Principal Assessor Name	Carlos
Additional Notes and Comments	
Contacts	

Summary Percent Compliance

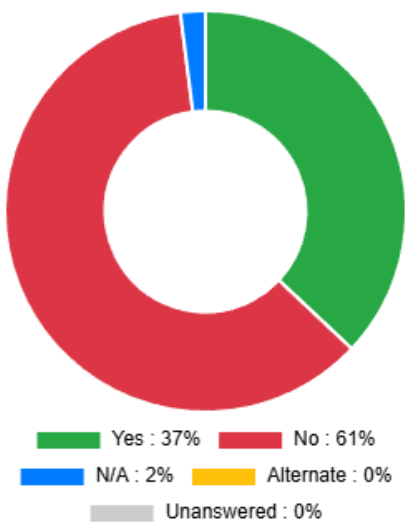


Executive Summary

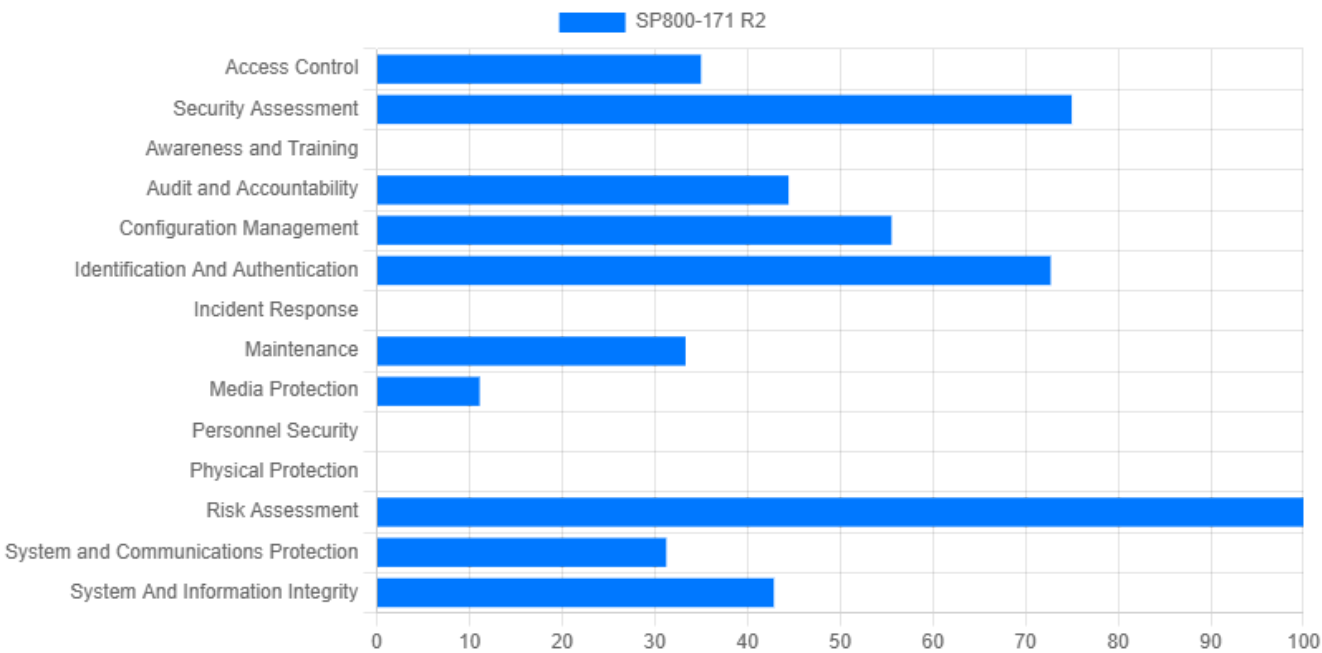
Cyber terrorism is a real and growing threat. Standards and guides have been developed, vetted, and widely accepted to assist with protection from cyber attacks. The Cyber Security Evaluation Tool (CSET) includes a selectable array of these standards for a tailored assessment of cyber vulnerabilities. Once the standards were selected and the resulting question sets answered, the CSET created a compliance summary, compiled variance statistics, ranked top areas of concern, and generated security recommendations.

Evaluation Against Selected Standards and Question Sets

Standards Summary

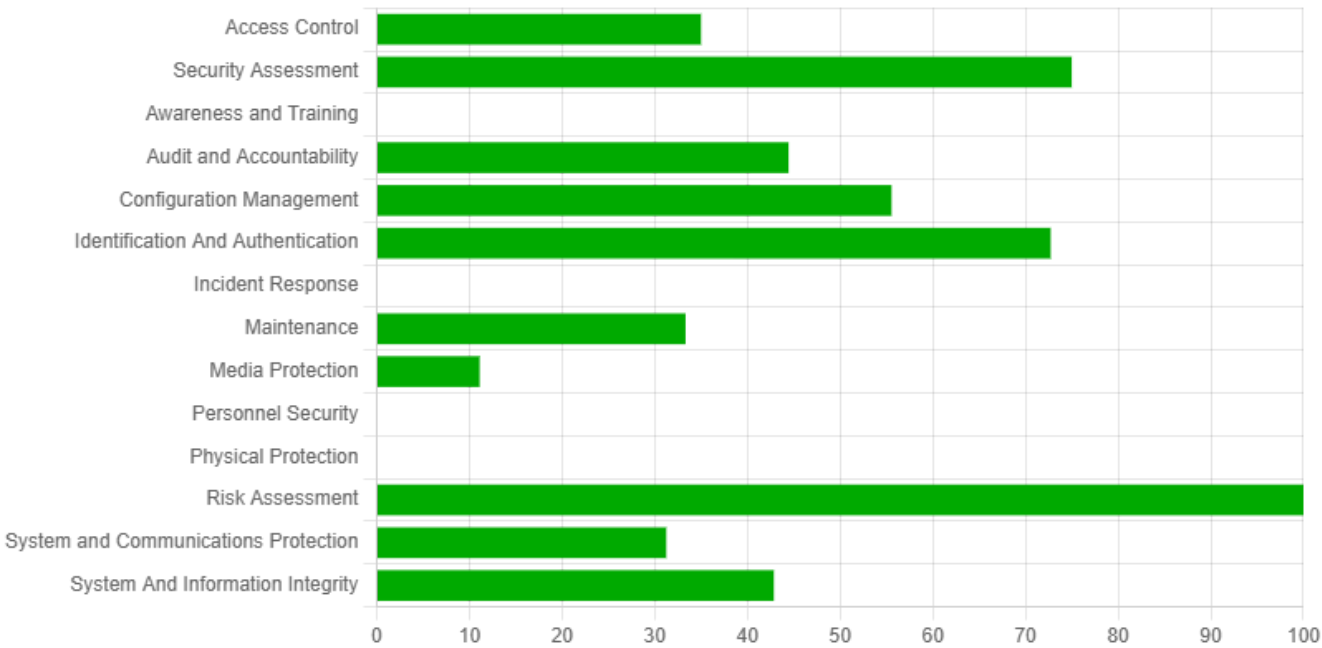


Standard or Question Set



Standards Compliance

SP800-171 R2



Security Assurance Level (SAL)

CALCULATED LEVEL

High

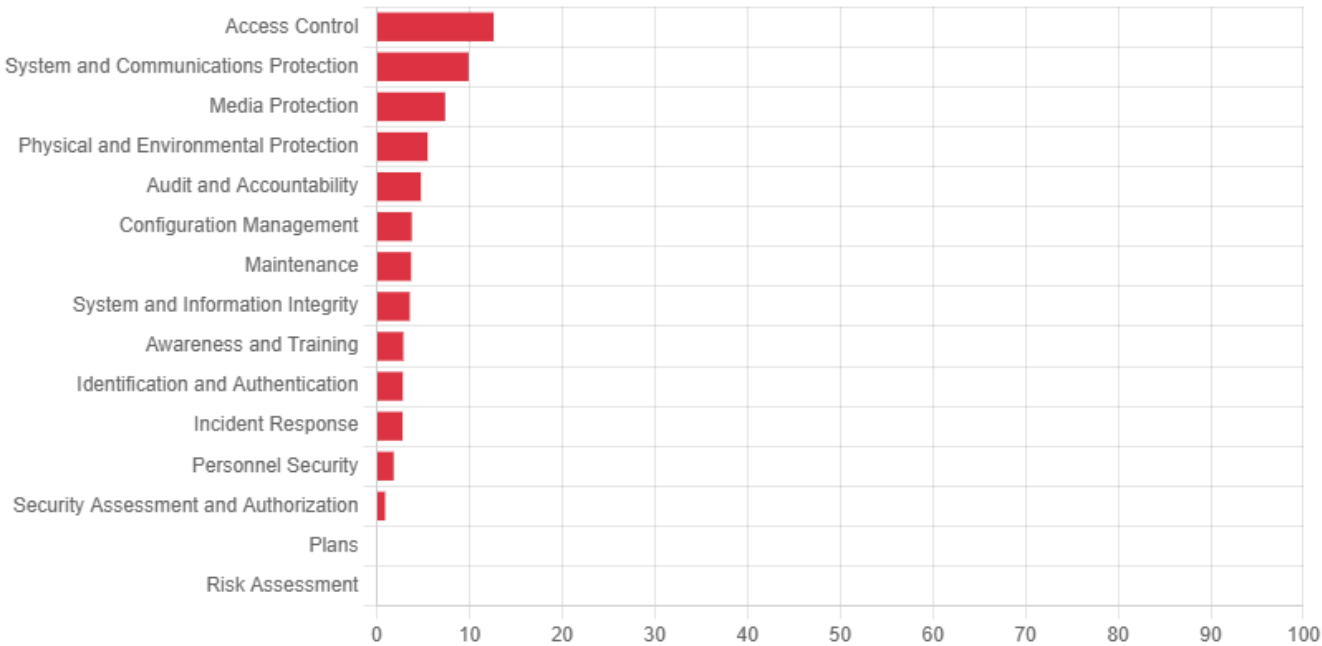
	Confidentiality	Integrity	Availability
Overall Values	Moderate	High	Moderate

Document Library

Title	File Name
There are no documents to display	

Ranked Categories

This chart ranks the top areas of concern based on a weighted risk score. The percentages are calculated by assigning higher weights to requirements that, if not implemented, would make the system more vulnerable to easier attacks. Lower weights are assigned to requirements associated with more difficult attacks.



Summary of Ranked Questions

Each question that did not meet the required Security Assurance Level (SAL) is shown in ranking order below. The displayed levels are the SALs applicable to that question. They are: Low (L), Moderate (M), High (H), and Very High (VH). CNSSI levels are for Confidentiality (C), Integrity (I), and Availability (A). DoD Instruction 8500.2 levels are for Confidentiality (Conf) and Mission Assurance Category (MAC). They are: Classified (C), Sensitive (S), and Public (P) for Confidentiality; MAC I, II, and III for Mission Assurance Category.

Rank: 1	Access Control #3.1.3	Level: High
Control the flow of CUI in accordance with approved authorizations.		No

Rank: 2	Access Control #3.1.4	Level: High
Separate the duties of individuals to reduce the risk of malevolent activity without collusion.		No

Rank: 3	Access Control #3.1.5	Level: High
Employ the principle of least privilege, including for specific security functions and privileged accounts.		No

Rank: 4	Access Control #3.1.6	Level: High
Use non-privileged accounts or roles when accessing non-security functions.		No

Rank: 5	Access Control #3.1.7	Level: High
Prevent non-privileged users from executing privileged functions and capture the execution of such functions in audit logs.		No

Rank: 6	Access Control #3.1.9	Level: High
Provide privacy and security notices consistent with applicable CUI rules.		No

Rank: 7	Access Control #3.1.12	Level: High
Monitor and control remote access sessions.		No
Rank: 8	Access Control #3.1.14	Level: High
Route remote access via managed access control points.		No
Rank: 9	Access Control #3.1.15	Level: High
Authorize remote execution of privileged commands and remote access to security-relevant information.		No
Rank: 10	Access Control #3.1.16	Level: High
Authorize wireless access prior to allowing such connections.		No
Rank: 11	Access Control #3.1.17	Level: High
Protect wireless access using authentication and encryption.		No
Rank: 12	Access Control #3.1.18	Level: High
Control connection of mobile devices.		No
Rank: 13	Access Control #3.1.21	Level: High
Limit use of portable storage devices on external systems.		No
Rank: 14	Awareness and Training #3.2.1	Level: High

Ensure that managers, systems administrators, and users of organizational systems are made aware of the security risks associated with their activities and of the applicable policies, standards, and procedures related to the security of those systems.	No
---	----

Rank: 15	Awareness and Training #3.2.2	Level: High
Ensure that personnel are trained to carry out their assigned information security-related duties and responsibilities.		No

Rank: 16	Awareness and Training #3.2.3	Level: High
Provide security awareness training on recognizing and reporting potential indicators of insider threat.		No

Rank: 17	Audit and Accountability #3.3.3	Level: High
Review and update logged events.		No

Rank: 18	Audit and Accountability #3.3.4	Level: High
Alert in the event of an audit logging process failure.		No

Rank: 19	Audit and Accountability #3.3.5	Level: High
Correlate audit record review, analysis, and reporting processes for investigation and response to indications of unlawful, unauthorized, suspicious, or unusual activity.		No

Rank: 20	Audit and Accountability #3.3.6	Level: High
Provide audit record reduction and report generation to support on-demand analysis and reporting.		No

Rank: 21	Audit and Accountability #3.3.7	Level: High
Provide a system capability that compares and synchronizes internal system clocks with an authoritative source to generate time stamps for audit records.		No
Rank: 22	Configuration Management #3.4.5	Level: High
Define, document, approve, and enforce physical and logical access restrictions associated with changes to organizational systems.		No
Rank: 23	Configuration Management #3.4.7	Level: High
Restrict, disable, and prevent the use of nonessential programs, functions, ports, protocols, and services.		No
Rank: 24	Configuration Management #3.4.8	Level: High
Apply deny-by-exception (blacklisting) policy to prevent the use of unauthorized software or deny-all, permit-by-exception (whitelisting) policy to allow the execution of authorized software.		No
Rank: 25	Configuration Management #3.4.9	Level: High
Control and monitor user-installed software.		No
Rank: 26	Identification And Authentication #3.5.3	Level: High
Use multifactor authentication for local and network access to privileged accounts and for network access to non-privileged accounts.		No
Rank: 27	Identification And Authentication #3.5.6	Level: High
Disable identifiers after a defined period of inactivity.		No

Rank: 28	Identification And Authentication #3.5.11	Level: High
Obscure feedback of authentication information.		No

Rank: 29	Incident Response #3.6.1	Level: High
Establish an operational incident-handling capability for organizational systems that includes preparation, detection, analysis, containment, recovery, and user response activities.		No

Rank: 30	Incident Response #3.6.2	Level: High
Track, document, and report incidents to designated officials and/or authorities both internal and external to the organization.		No

Rank: 31	Incident Response #3.6.3	Level: High
Test the organizational incident response capability.		No

Rank: 32	Maintenance #3.7.2	Level: High
Provide controls on the tools, techniques, mechanisms, and personnel used to conduct system maintenance.		No

Rank: 33	Maintenance #3.7.3	Level: High
Ensure equipment removed for off-site maintenance is sanitized of any CUI.		No

Rank: 34	Maintenance #3.7.5	Level: High
Require multifactor authentication to establish nonlocal maintenance sessions via external network connections and terminate such connections when nonlocal maintenance is complete.		No

Rank: 35	Maintenance #3.7.6	Level: High
Supervise the maintenance activities of maintenance personnel without required access authorization.		No
Rank: 36	Media Protection #3.8.1	Level: High
Protect (i.e., physically control and securely store) system media containing CUI, both paper and digital.		No
Rank: 37	Media Protection #3.8.3	Level: High
Sanitize or destroy system media containing CUI before disposal or release for reuse.		No
Rank: 38	Media Protection #3.8.4	Level: High
Mark media with necessary CUI markings and distribution limitations.		No
Rank: 39	Media Protection #3.8.5	Level: High
Control access to media containing CUI and maintain accountability for media during transport outside of controlled areas.		No
Rank: 40	Media Protection #3.8.6	Level: High
Implement cryptographic mechanisms to protect the confidentiality of CUI stored on digital media during transport unless otherwise protected by alternative physical safeguards.		No
Rank: 41	Media Protection #3.8.7	Level: High
Control the use of removable media on system components.		No

Rank: 42	Media Protection #3.8.8	Level: High
Prohibit the use of portable storage devices when such devices have no identifiable owner.		No
Rank: 43	Media Protection #3.8.9	Level: High
Protect the confidentiality of backup CUI at storage locations.		No
Rank: 44	Personnel Security #3.9.1	Level: High
Screen individuals prior to authorizing access to organizational systems containing CUI.		No
Rank: 45	Personnel Security #3.9.2	Level: High
Ensure that organizational systems containing CUI are protected during and after personnel actions such as terminations and transfers.		No
Rank: 46	Physical Protection #3.10.1	Level: High
Limit physical access to organizational systems, equipment, and the respective operating environments to authorized individuals.		No
Rank: 47	Physical Protection #3.10.2	Level: High
Protect and monitor the physical facility and support infrastructure for organizational systems.		No
Rank: 48	Physical Protection #3.10.3	Level: High
Escort visitors and monitor visitor activity.		No

Rank: 49	Physical Protection #3.10.4	Level: High
Maintain audit logs of physical access.		No

Rank: 50	Physical Protection #3.10.5	Level: High
Control and manage physical access devices.		No

Rank: 51	Physical Protection #3.10.6	Level: High
Enforce safeguarding measures for CUI at alternate work sites.		No

Rank: 52	Security Assessment #3.12.3	Level: High
Monitor security controls on an ongoing basis to ensure the continued effectiveness of the controls.		No

Rank: 53	System and Communications Protection #3.13.1	Level: High
Monitor, control, and protect communications (i.e., information transmitted or received by organizational systems) at the external boundaries and key internal boundaries of organizational systems.		No

Rank: 54	System and Communications Protection #3.13.4	Level: High
Prevent unauthorized and unintended information transfer via shared system resources.		No

Rank: 55	System and Communications Protection #3.13.6	Level: High
Deny network communications traffic by default and allow network communications traffic by exception (i.e., deny all, permit by exception).		No

Rank: 56	System and Communications Protection #3.13.7	Level: High
Prevent remote devices from simultaneously establishing non-remote connections with organizational systems and communicating via some other connection to resources in external networks (i.e., split tunneling).		No
Rank: 57	System and Communications Protection #3.13.8	Level: High
Implement cryptographic mechanisms to prevent unauthorized disclosure of CUI during transmission unless otherwise protected by alternative physical safeguards.		No
Rank: 58	System and Communications Protection #3.13.10	Level: High
Establish and manage cryptographic keys for cryptography employed in organizational systems.		No
Rank: 59	System and Communications Protection #3.13.11	Level: High
Employ FIPS-validated cryptography when used to protect the confidentiality of CUI.		No
Rank: 60	System and Communications Protection #3.13.12	Level: High
Prohibit remote activation of collaborative computing devices and provide indication of devices in use to users present at the device.		No
Rank: 61	System and Communications Protection #3.13.13	Level: High
Control and monitor the use of mobile code.		No
Rank: 62	System and Communications Protection #3.13.14	Level: High
Control and monitor the use of Voice over Internet Protocol (VoIP) technologies.		No

Rank: 63	System and Communications Protection #3.13.16	Level: High
Protect the confidentiality of CUI at rest.		No

Rank: 64	System And Information Integrity #3.14.3	Level: High
Monitor system security alerts and advisories and take action in response.		No

Rank: 65	System And Information Integrity #3.14.4	Level: High
Update malicious code protection mechanisms when new releases are available.		No

Rank: 66	System And Information Integrity #3.14.6	Level: High
Monitor organizational systems, including inbound and outbound communications traffic, to detect attacks and indicators of potential attacks.		No

Rank: 67	System And Information Integrity #3.14.7	Level: High
Identify unauthorized use of organizational systems.		No

Questions Comments

There are no comments to display

Alternate Justification

There are no questions with alternate justifications to display.

Questions Marked for Review

There are no questions marked for review.